
VENDOR MANAGEMENT POLICY

Document ID: POL-PROC-005 Version: v1.5 Effective Date: November 10, 2023 Review Date: November 10, 2024 Policy Owner: Procurement & Risk Management Approval Authority: Chief Financial Officer and Chief Information Security Officer Classification: Internal Use Only

1. PURPOSE

This policy establishes Acme Corporation's requirements for the selection, onboarding, ongoing management, and offboarding of third-party vendors and business partners. The objective is to ensure that risks introduced by third parties are identified, assessed, and appropriately mitigated to protect Acme Corporation's information assets, operational continuity, and regulatory standing.

2. SCOPE

This policy applies to all vendors, subcontractors, and business partners that provide services to Acme Corporation or that are granted access to Acme Corporation systems, networks, or data. It covers both technology vendors (including cloud service providers and managed service providers) and non-technology vendors whose services involve access to sensitive company information.

3. VENDOR RISK MANAGEMENT (CC9.2)

3.1 Vendor Risk Assessment and Onboarding

Prior to onboarding a new vendor, Procurement & Risk Management conducts a formal vendor risk assessment scaled to the sensitivity of the engagement:

- (a) Risk Tiering: Vendors are assigned a risk tier (Critical, High, Medium, Low) based on the type of data they access, the criticality of services provided, and the degree of integration with Acme Corporation systems.
- (b) Security Assessment: Critical and High-tier vendors must complete a security questionnaire covering their information security controls, data protection practices, incident response capabilities, and relevant certifications. Where available, current SOC 2 Type II reports, ISO 27001 certificates, or equivalent third-party assurances are collected and reviewed.
- (c) Financial and Reputational Due Diligence: Procurement conducts background checks on new vendors to assess financial stability and reputational risk prior to contract execution.
- (d) Approval: Vendor onboarding requires written approval from the business sponsor, the Procurement team, and — for Critical or High-tier vendors — the Information Security Team.

3.2 Contractual Security Requirements

All vendor contracts must include provisions addressing:

- (a) Data Protection: Requirements for vendors to protect Acme Corporation data in accordance with applicable law and Acme Corporation's data classification standards. This includes encryption of data in transit and at rest, restrictions on subprocessor use, and data deletion upon contract termination.
- (b) Security Incident Notification: Vendors must notify Acme Corporation's designated contact within 24 hours of discovering a security incident or suspected breach involving Acme Corporation data.
- (c) Audit Rights: Acme Corporation reserves the right to audit vendor security controls or require evidence of compliance with contractual security obligations on reasonable notice.
- (d) Right to Terminate: Contracts must include provisions allowing Acme Corporation to terminate the relationship without penalty in the event of a material security breach or sustained non-compliance.

3.3 Ongoing Vendor Monitoring

Following onboarding, vendors are subject to ongoing performance and risk monitoring:

- (a) Periodic Review: Critical and High-tier vendors are reviewed annually; Medium- tier vendors are reviewed every 18 months. Reviews assess current SOC reports or equivalent security certifications, security questionnaire updates, and any known incidents or breaches.
- (b) Service Level Monitoring: Procurement monitors vendor performance against contractually agreed service levels and escalates sustained underperformance to vendor account management.
- (c) Incident Tracking: Security incidents reported by vendors are logged in the incident tracking system and evaluated by the Information Security Team to assess impact on Acme Corporation systems or data.

3.4 Vendor Offboarding

When a vendor relationship is terminated, the following steps are completed:

- (a) Access Revocation: All logical and physical access granted to the vendor is revoked within one (1) business day of the contract end date or earlier notice of termination.
- (b) Data Return and Deletion: The vendor is required to return or certifiably destroy all Acme Corporation data within 30 days of contract termination, with written confirmation provided to Procurement.
- (c) Final Assessment: A closing review is documented, including any open issues, lessons learned, and confirmation that contractual wind-down obligations have been satisfied.

4. VENDOR ACCESS TO SYSTEMS

Vendors granted access to Acme Corporation systems are subject to the same access control requirements applicable to internal users, including unique account credentials, least-privilege access, and multi-factor authentication where required.

Vendor access is reviewed as part of the periodic vendor review cycle.

5. RESPONSIBILITIES

- Procurement & Risk Management: Owns and administers this policy; manages vendor onboarding, contract review, and ongoing monitoring activities.
- Information Security Team: Conducts security assessments for Critical and High-tier vendors; reviews vendor incident reports; approves security contract terms.
- Business Sponsors: Identify vendor requirements; serve as primary relationship contacts; participate in vendor performance reviews.
- Legal: Reviews and approves contractual terms; advises on data protection obligations and breach notification requirements.

6. EXCEPTIONS

Exceptions to vendor risk assessment requirements must be approved by both the Procurement lead and the Information Security Team and documented with a defined remediation plan and timeline.

7. RELATED DOCUMENTS

- Information Security Policy (POL-SEC-002)
- Data Classification and Handling Policy (POL-SEC-003)
- Access Control Policy (POL-SEC-001)
- Third-Party Questionnaire Template (TMPL-PROC-002)

REVISION HISTORY

Version	Date	Author	Description
v1.0	2022-03-14	Procurement & Risk	Initial release
v1.2	2022-11-01	Procurement & Risk	Added SOC 2 review requirement; expanded offboarding procedures
v1.5	2023-11-10	Procurement & Risk	Updated risk tiering criteria; added CSPM and cloud vendor guidance